Lab 5: Static Code Analysis

Parking Lot System (`parking_lot_system.py`)

Name	SAMPATH
SRN	PES1UG24CS416
Assigned repo	github.com/SETAPESU26/L5_51_parking_lot_system
Submission repo	github.com/Sampath-404/SE-Labs-PES1UG24CS416 (folder Lab5)
Tools used	Pylint 4.1.3, Bandit 1.9.4, Flake8 7.5.0 (Python 3.13)
Date	30 October 2026

Contents

1. Introduction to static code analysis and the three tools
2. Screenshots of issues found before fixing
3. Issue identification table
4. Before and after reports (all six .txt files)
5. Screenshots after fixing
6. Reflection questions

1. Introduction to Static Code Analysis

Static code analysis means examining source code **without running it** to find bugs, security vulnerabilities and style violations early, when they are cheapest to fix. It is fast, repeatable and can run automatically in an editor or CI pipeline, but it can only flag patterns it knows about. It cannot judge business logic, so human review is still needed.

The three tools used in this lab

Tool	Role	What it checks	Example in this lab
Pylint	Strict code reviewer	Code quality, logic errors, naming, docstrings, unused code, bad practices. Gives a score out of 10.	W0102 dangerous default value [], W0702 bare-except, 4.10/10 score
Bandit	Security guard	Common security problems: dangerous functions, weak crypto, shell injection. Reports severity and confidence.	B605 os.system (High), B324 MD5 (High), B307 eval (Medium)
Flake8	Grammar checker	PEP 8 style: line length, whitespace, unused imports and variables, syntax problems.	E501 line too long, F401 unused import, W292 no newline at end

Program analysed: an automated parking lot manager that parks vehicles by licence plate, frees slots, computes surge fees, hashes plates, generates ticket PINs and exports a manifest file.

Summary of results: Pylint 4.10/10 to 10.00/10, Bandit 5 issues (2 High, 1 Medium, 2 Low) to 0, Flake8 10 warnings to 0. The fixes were committed in three separate commits, one per tool.

2. Issues Identified Before Fixing

```
(venv) PS C:\Users\Lenovo\AppData\Local\Temp\orig_lab5> pylint parking_lot_system.py
************* Module parking_lot_system
parking_lot_system.py:23:0: C0301: Line too long (131/100) (line-too-long)
parking_lot_system.py:88:0: C0304: Final newline missing (missing-final-newline)
parking_lot_system.py:1:0: C0114: Missing module docstring (missing-module-docstring)
parking_lot_system.py:12:0: C0103: Constant name "total_collections" doesn't conform to UPPER_CASE naming style (invalid-name)
parking_lot_system.py:15:0: C0116: Missing function or method docstring (missing-function-docstring)
parking_lot_system.py:15:0: C0103: Function name "parkVehicle" doesn't conform to snake_case naming style (invalid-name)
parking_lot_system.py:15:0: W0102: Dangerous default value [] as argument (dangerous-default-value)
parking_lot_system.py:16:4: W0603: Using the global statement (global-statement)
parking_lot_system.py:23:22: C0209: Formatting a regular string which could be an f-string (consider-using-f-string)
parking_lot_system.py:27:0: C0116: Missing function or method docstring (missing-function-docstring)
parking_lot_system.py:27:0: C0103: Function name "releaseSlot" doesn't conform to snake_case naming style (invalid-name)
parking_lot_system.py:32:4: W0702: No exception type(s) specified (bare-except)
parking_lot_system.py:36:0: C0116: Missing function or method docstring (missing-function-docstring)
parking_lot_system.py:36:0: C0103: Function name "checkSlotAvailability" doesn't conform to snake_case naming style (invalid-name)
parking_lot_system.py:38:7: C0121: Comparison 'parking_slots.get(slot_id) == None' should be 'parking_slots.get(slot_id) is None' (singleton-comparison)
parking_lot_system.py:40:4: R1703: The if statement can be replaced with 'return bool(test)' (simplifiable-if-statement)
parking_lot_system.py:40:4: R1705: Unnecessary "else" after "return", remove the "else" and de-indent the code inside it (no-else-return)
parking_lot_system.py:37:4: W0612: Unused variable 'overtime_fee' (unused-variable)
parking_lot_system.py:46:0: C0116: Missing function or method docstring (missing-function-docstring)
parking_lot_system.py:46:0: C0103: Function name "calculateParkingFee" doesn't conform to snake_case naming style (invalid-name)
parking_lot_system.py:48:16: W0123: Use of eval (eval-used)
parking_lot_system.py:47:4: W0612: Unused variable 'base_rate' (unused-variable)
parking_lot_system.py:52:0: C0116: Missing function or method docstring (missing-function-docstring)
parking_lot_system.py:52:0: C0103: Function name "generateVehicleHash" doesn't conform to snake_case naming style (invalid-name)
parking_lot_system.py:56:0: C0116: Missing function or method docstring (missing-function-docstring)
parking_lot_system.py:56:0: C0103: Function name "generateTicketPin" doesn't conform to snake_case naming style (invalid-name)
parking_lot_system.py:60:0: C0116: Missing function or method docstring (missing-function-docstring)
parking_lot_system.py:60:0: C0103: Function name "exportParkingManifest" doesn't conform to snake_case naming style (invalid-name)
parking_lot_system.py:61:8: W1514: Using open without explicitly specifying an encoding (unspecified-encoding)
parking_lot_system.py:61:8: R1732: Consider using 'with' for resource-allocating operations (consider-using-with)
parking_lot_system.py:67:0: C0116: Missing function or method docstring (missing-function-docstring)
parking_lot_system.py:67:0: C0103: Function name "getAvailableSummary" doesn't conform to snake_case naming style (invalid-name)
parking_lot_system.py:67:24: W0621: Redefining name 'parking_slots' from outer scope (line 6) (redefined-outer-name)
parking_lot_system.py:69:8: W0612: Unused variable 's' (unused-variable)
parking_lot_system.py:75:0: C0116: Missing function or method docstring (missing-function-docstring)
parking_lot_system.py:4:0: W0611: Unused import math (unused-import)

-------------------------------------------------------------------
Your code has been rated at 4.10/10 (previous run: 10.00/10, -5.90)

(venv) PS C:\Users\Lenovo\AppData\Local\Temp\orig_lab5>
```

Figure 1: Pylint output before fixing (score 4.10/10).

```
(venv) PS C:\Users\Lenovo\AppData\Local\Temp\orig_lab5> bandit -r parking_lot_system.py
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.13.0
Run started:2026-10-30 03:41:03.454994+00:00

Test results:
>> Issue: [B110:try_except_pass] Try, Except, Pass detected.
   Severity: Low   Confidence: High
   CWE: CWE-703 (https://cwe.mitre.org/data/definitions/703.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b110_try_except_pass.html
   Location: .\parking_lot_system.py:32:4
31              parking_slots[slot_id]["hours"] = 0
32          except:
33              pass
34

--------------------------------------------------
>> Issue: [B307:blacklist] Use of possibly insecure function - consider using safer ast.literal_eval.
   Severity: Medium   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b307-eval
   Location: .\parking_lot_system.py:48:16
47          base_rate = parking_slots[slot_id]["rate"]
48          final_fee = eval(surge_expr)
49          return final_fee

--------------------------------------------------
>> Issue: [B324:hashlib] Use of weak MD5 hash for security. Consider usedforsecurity=False
   Severity: High   Confidence: High
   CWE: CWE-327 (https://cwe.mitre.org/data/definitions/327.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b324_hashlib.html
   Location: .\parking_lot_system.py:53:11
```

Figure 2: Bandit output before fixing (part 1 of 2): B110, B307 and start of B324.

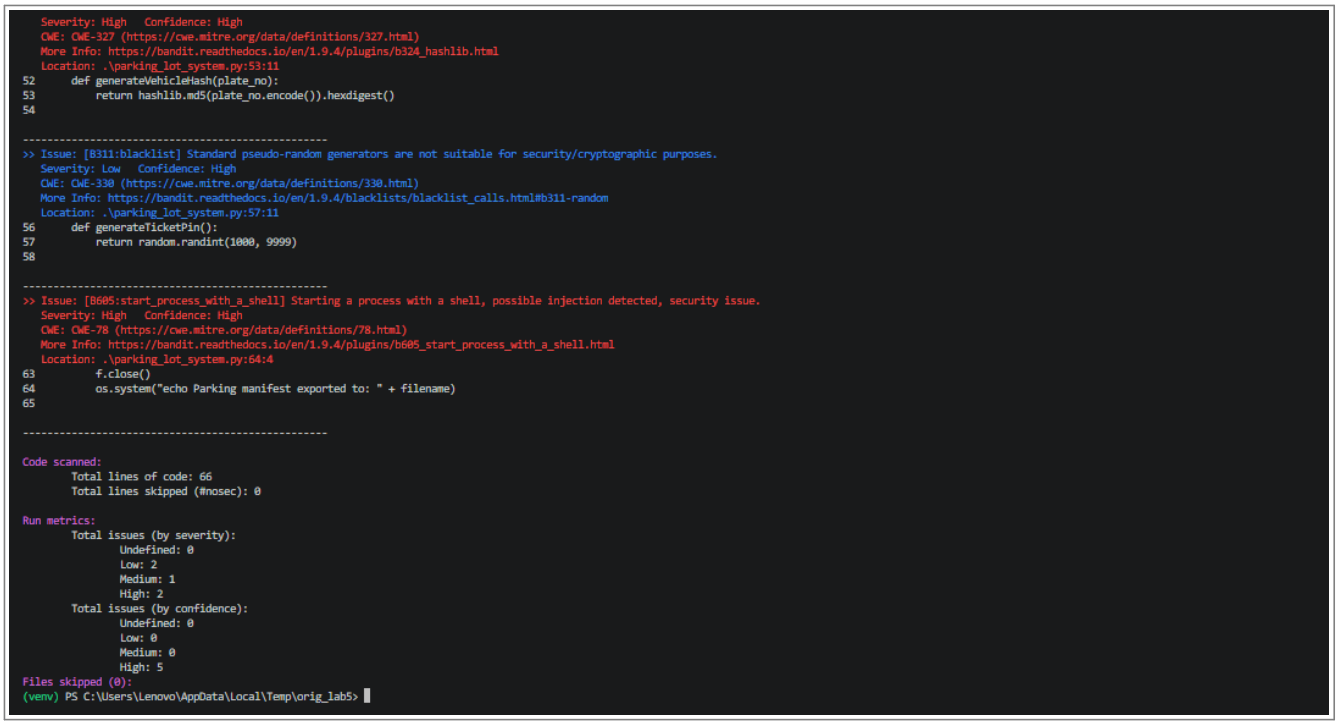


Figure 3: Bandit output before fixing (part 2 of 2): B324, B311, B605 and the summary (High 2, Medium 1, Low 2).

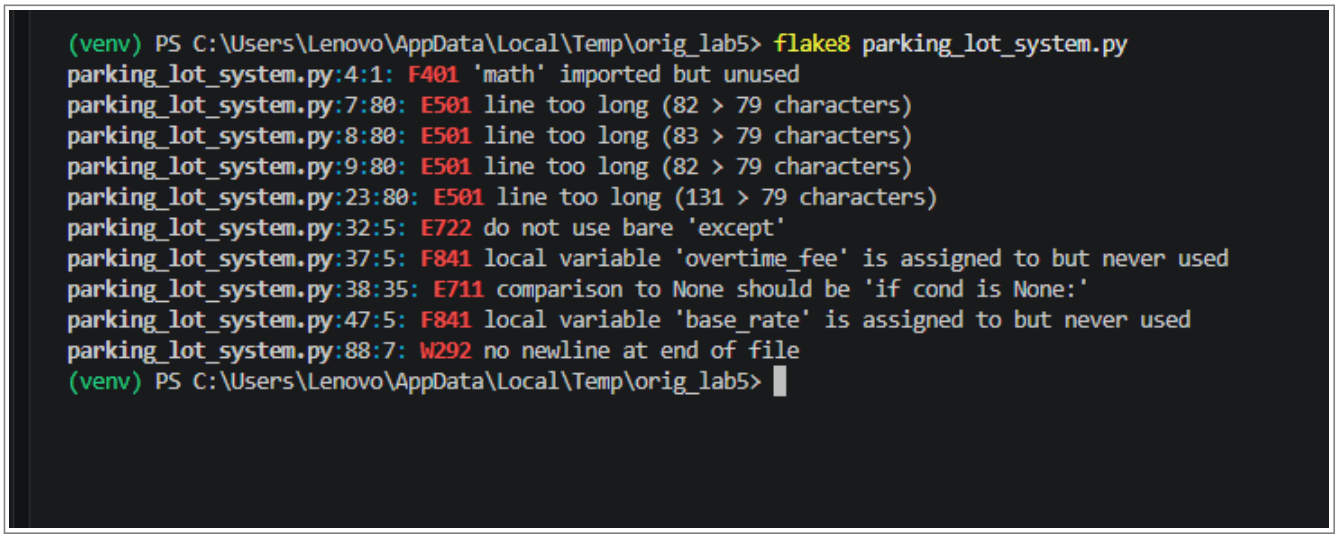


Figure 4: Flake8 output before fixing (10 warnings).

3. Issue Identification Table

Line numbers refer to the original file. Issues are ordered by severity, security first.

Issue	Type	Line(s)	Description	Fix Approach
Shell command via os.system (Bandit B605, High)	Security	64	Filename concatenated into a shell command, so command injection is possible	Removed os.system; used print()
Weak MD5 hash (Bandit B324, High)	Security	53	MD5 is cryptographically broken	Switched to hashlib.sha256
eval() on caller-supplied string (Bandit B307, Medium / Pylint W0123)	Security	48, 80	Arbitrary code execution through surge_expr	Replaced the expression string with a numeric surge_multiplier
Hardcoded secret (not flagged by tools)	Security	76, 85	Gate key in source code and printed to console	Read from env var BARRIER_GATE_KEY; print only whether it is configured
Insecure random for PIN (Bandit B311, Low)	Security	57	random is predictable	Used secrets.randbelow(9000) + 1000
Bare except: pass (B110 / W0702 / E722)	Bug	32-33	Hides every error silently	Catch KeyError only and return False
Mutable default argument entry_logs=[] (W0102)	Bug	15	List shared across all calls	Default None, create a new list inside the function
No validation of hours_booked (not flagged by tools)	Bug	15-22	Zero or negative hours would corrupt collections	Return False if hours_booked <= 0
File opened without with / encoding (R1732, W1514)	Bug	61-63	File may stay open if write fails	Used with open(..., encoding="utf-8")
Global statement / constant naming (W0603, C0103)	Style	12, 16	Mutable global state	Replaced with a STATS dict; constants are UPPER_CASE
camelCase function names (C0103)	Style	15-67	Not PEP 8	Renamed to snake_case
Missing docstrings (C0114, C0116)	Style	all	No documentation	Added module and function docstrings
Unused import math, unused variables overtime_fee, base_rate, s (F401, F841, W0611, W0612)	Style	4, 37, 47, 69	Dead code	Removed them
== None, needless else, % formatting (E711, C0121, R1705, C0209)	Style	23, 38, 40-43	Non-idiomatic code	Used is None, return not ..., f-strings
Shadowed name parking_slots (W0621)	Style	67	Parameter hides the global	Renamed parameter to slots
Line too long, missing final newline (E501, W292, C0301, C0304)	Style	7-9, 23, 88	PEP 8 violations	Wrapped lines; file ends with newline
main() runs on import (not flagged)	Design	88	Importing the module runs the demo	Added if __name__ == "__main__":

4. Before and After Reports (contents of all six .txt files)

The six files are in the repository under Lab5/before and Lab5/after. Their full contents are reproduced below.

4.1 Before fixing

before/pylint_report.txt

```
************* Module parking_lot_system
parking_lot_system.py:23:0: C0301: Line too long (131/100) (line-too-long)
parking_lot_system.py:88:0: C0304: Final newline missing (missing-final-newline)
parking_lot_system.py:1:0: C0114: Missing module docstring (missing-module-docstring)
parking_lot_system.py:12:0: C0103: Constant name "total_collections" doesn't conform to UPPER_CASE naming style (invalid-
  name)
parking_lot_system.py:15:0: C0116: Missing function or method docstring (missing-function-docstring)
parking_lot_system.py:15:0: C0103: Function name "parkVehicle" doesn't conform to snake_case naming style (invalid-name)
parking_lot_system.py:15:0: W0102: Dangerous default value [] as argument (dangerous-default-value)
parking_lot_system.py:16:4: W0603: Using the global statement (global-statement)
parking_lot_system.py:23:22: C0209: Formatting a regular string which could be an f-string (consider-using-f-string)
parking_lot_system.py:27:0: C0116: Missing function or method docstring (missing-function-docstring)
parking_lot_system.py:27:0: C0103: Function name "releaseSlot" doesn't conform to snake_case naming style (invalid-name)
parking_lot_system.py:32:4: W0702: No exception type(s) specified (bare-except)
parking_lot_system.py:36:0: C0116: Missing function or method docstring (missing-function-docstring)
parking_lot_system.py:36:0: C0103: Function name "checkSlotAvailability" doesn't conform to snake_case naming style
  (invalid-name)
parking_lot_system.py:38:7: C0121: Comparison 'parking_slots.get(slot_id) == None' should be 'parking_slots.get(slot_id)
  is None' (singleton-comparison)
parking_lot_system.py:40:4: R1703: The if statement can be replaced with 'return bool(test)' (simplifiable-if-statement)
parking_lot_system.py:40:4: R1705: Unnecessary "else" after "return", remove the "else" and de-indent the code inside it
  (no-else-return)
parking_lot_system.py:37:4: W0612: Unused variable 'overtime_fee' (unused-variable)
parking_lot_system.py:46:0: C0116: Missing function or method docstring (missing-function-docstring)
parking_lot_system.py:46:0: C0103: Function name "calculateParkingFee" doesn't conform to snake_case naming style
  (invalid-name)
parking_lot_system.py:48:16: W0123: Use of eval (eval-used)
parking_lot_system.py:47:4: W0612: Unused variable 'base_rate' (unused-variable)
parking_lot_system.py:52:0: C0116: Missing function or method docstring (missing-function-docstring)
parking_lot_system.py:52:0: C0103: Function name "generateVehicleHash" doesn't conform to snake_case naming style
  (invalid-name)
parking_lot_system.py:56:0: C0116: Missing function or method docstring (missing-function-docstring)
parking_lot_system.py:56:0: C0103: Function name "generateTicketPin" doesn't conform to snake_case naming style (invalid-
  name)
parking_lot_system.py:60:0: C0116: Missing function or method docstring (missing-function-docstring)
parking_lot_system.py:60:0: C0103: Function name "exportParkingManifest" doesn't conform to snake_case naming style
  (invalid-name)
parking_lot_system.py:61:8: W1514: Using open without explicitly specifying an encoding (unspecified-encoding)
parking_lot_system.py:61:8: R1732: Consider using 'with' for resource-allocating operations (consider-using-with)
parking_lot_system.py:67:0: C0116: Missing function or method docstring (missing-function-docstring)
parking_lot_system.py:67:0: C0103: Function name "getAvailableSummary" doesn't conform to snake_case naming style
  (invalid-name)
parking_lot_system.py:67:24: W0621: Redefining name 'parking_slots' from outer scope (line 6) (redefined-outer-name)
parking_lot_system.py:69:8: W0612: Unused variable 's' (unused-variable)
parking_lot_system.py:75:0: C0116: Missing function or method docstring (missing-function-docstring)
parking_lot_system.py:4:0: W0611: Unused import math (unused-import)

-----------------------------------
Your code has been rated at 4.10/10
```

before/bandit_report.txt

```
Run started:2026-10-30 03:19:33.095938+00:00

Test results:
>> Issue: [B110:try_except_pass] Try, Except, Pass detected.
   Severity: Low   Confidence: High
   CWE: CWE-703 (https://cwe.mitre.org/data/definitions/703.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b110_try_except_pass.html
   Location: .\parking_lot_system.py:32:4
31             parking_slots[slot_id]["hours"] = 0
32         except:
33             pass
34

--------------------------------------------------
>> Issue: [B307:blacklist] Use of possibly insecure function - consider using safer ast.literal_eval.
   Severity: Medium   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b307-eval
   Location: .\parking_lot_system.py:48:16
47         base_rate = parking_slots[slot_id]["rate"]
48         final_fee = eval(surge_expr)
49         return final_fee

--------------------------------------------------
>> Issue: [B324:hashlib] Use of weak MD5 hash for security. Consider usedforsecurity=False
   Severity: High   Confidence: High
   CWE: CWE-327 (https://cwe.mitre.org/data/definitions/327.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b324_hashlib.html
   Location: .\parking_lot_system.py:53:11
52     def generateVehicleHash(plate_no):
53         return hashlib.md5(plate_no.encode()).hexdigest()
54

--------------------------------------------------
>> Issue: [B311:blacklist] Standard pseudo-random generators are not suitable for security/cryptographic purposes.
   Severity: Low   Confidence: High
   CWE: CWE-330 (https://cwe.mitre.org/data/definitions/330.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b311-random
   Location: .\parking_lot_system.py:57:11
56     def generateTicketPin():
57         return random.randint(1000, 9999)
58

--------------------------------------------------
>> Issue: [B605:start_process_with_a_shell] Starting a process with a shell, possible injection detected, security issue.
   Severity: High   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b605_start_process_with_a_shell.html
   Location: .\parking_lot_system.py:64:4
63         f.close()
64         os.system("echo Parking manifest exported to: " + filename)
65

--------------------------------------------------

Code scanned:
    Total lines of code: 66
    Total lines skipped (#nosec): 0
    Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
    Total issues (by severity):
        Undefined: 0
        Low: 2
        Medium: 1
        High: 2
    Total issues (by confidence):
        Undefined: 0
        Low: 0
        Medium: 0
        High: 5
Files skipped (0):
```

before/flake8_report.txt

```
parking_lot_system.py:4:1: F401 'math' imported but unused
parking_lot_system.py:7:80: E501 line too long (82 > 79 characters)
parking_lot_system.py:8:80: E501 line too long (83 > 79 characters)
parking_lot_system.py:9:80: E501 line too long (82 > 79 characters)
parking_lot_system.py:23:80: E501 line too long (131 > 79 characters)
parking_lot_system.py:32:5: E722 do not use bare 'except'
parking_lot_system.py:37:5: F841 local variable 'overtime_fee' is assigned to but never used
parking_lot_system.py:38:35: E711 comparison to None should be 'if cond is None:'
parking_lot_system.py:47:5: F841 local variable 'base_rate' is assigned to but never used
parking_lot_system.py:88:7: W292 no newline at end of file
```

4.2 After fixing

after/pylint_report.txt

```
--------------------------------------------------------------------
Your code has been rated at 10.00/10 (previous run: 10.00/10, +0.00)
```

after/bandit_report.txt

```
Run started:2026-10-30 03:32:05.788979+00:00

Test results:
    No issues identified.

Code scanned:
    Total lines of code: 84
    Total lines skipped (#nosec): 0
    Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
    Total issues (by severity):
        Undefined: 0
        Low: 0
        Medium: 0
        High: 0
    Total issues (by confidence):
        Undefined: 0
        Low: 0
        Medium: 0
        High: 0
Files skipped (0):
```

after/flake8_report.txt

```
(empty file: 0 bytes. Flake8 reported no warnings.)
```

5. Results After Fixing

```
(venv) PS C:\Users\Lenovo\L5_51_parking_lot_system\SE-Labs-PES1UG24CS416\Lab5> pylint parking_lot_system.py

--------------------------------------------------------------------
Your code has been rated at 10.00/10 (previous run: 4.10/10, +5.90)

(venv) PS C:\Users\Lenovo\L5_51_parking_lot_system\SE-Labs-PES1UG24CS416\Lab5>
```

Figure 5: Pylint after fixing: 10.00/10.

```
(venv) PS C:\Users\Lenovo\L5_51_parking_lot_system\SE-Labs-PES1UG24CS416\Lab5> bandit -r parking_lot_system.py
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.13.0
Run started:2026-10-30 04:46:18.787672+00:00

Test results:
        No issues identified.

Code scanned:
        Total lines of code: 84
        Total lines skipped (#nosec): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
Files skipped (0):
(venv) PS C:\Users\Lenovo\L5_51_parking_lot_system\SE-Labs-PES1UG24CS416\Lab5>
```

Figure 6: Bandit after fixing: No issues identified (0 Low, 0 Medium, 0 High).

```
(venv) PS C:\Users\Lenovo\L5_51_parking_lot_system\SE-Labs-PES1UG24CS416\Lab5> flake8 parking_lot_system.py
(venv) PS C:\Users\Lenovo\L5_51_parking_lot_system\SE-Labs-PES1UG24CS416\Lab5>
```

Figure 7: Flake8 after fixing: no output, so no warnings.

```
(venv) PS C:\Users\Lenovo\L5_51_parking_lot_system\SE-Labs-PES1UG24CS416\Lab5> python parking_lot_system.py
Is P02 available: False
Surge Parking Fee: 45.0
Vehicle Hash: bd2cd41fd9d9c0045716b50de3536056cd9f8565f9cdb6d1745c639602f3f482
Ticket PIN: 6312
Parking manifest exported to: parking_manifest.txt
Vacant slots: 1
Barrier Key configured: False
(venv) PS C:\Users\Lenovo\L5_51_parking_lot_system\SE-Labs-PES1UG24CS416\Lab5>
```

Figure 8: The program still runs correctly after the fixes.

6. Reflection

Q1. Which tool found the most issues, and which was most useful?

Pylint reported the most (36 messages, score 4.10/10). Bandit was the most important, because it found the two High severity security flaws (os.system and MD5) and the eval call. Flake8 mostly confirmed style problems that Pylint had already caught.

Q2. Did you find any false positives or issues the tools missed?

Bandit flagged random for a parking PIN. The risk is low, but secrets was an easy fix, so I treated it as a real issue. The tools missed the hardcoded gate key (it was printed to the console) and the missing validation of hours_booked. I found these only by reading the code.

Q3. How would you integrate static analysis into a workflow?

Run the tools as a pre-commit hook and as a CI step on every pull request. Fail the build on Bandit High and Medium findings and on a Pylint score below 9.5, and keep Flake8 in the editor for instant feedback.

Q4. How did your code improve?

Pylint went from 4.10 to 10.00. Bandit went from 5 issues (2 High, 1 Medium, 2 Low) to 0, and Flake8 from 10 warnings to 0. The code is safer (no eval, no shell, SHA-256, secrets, no hardcoded key), more readable (snake_case, docstrings) and has fewer hidden bugs (no mutable default argument, no swallowed exceptions).

Git history (repository Sampath-404/SE-Labs-PES1UG24CS416)

Commit	Message
`2dce148`	Fix Bandit issues: remove eval/os.system, use sha256 and secrets, drop hardcoded key
`714011d`	Fix Pylint issues: snake_case, docstrings, mutable default, bare except, unused code
`21ffa9e`	Fix Flake8 issues: wrap long lines, add main guard
`cf7fdd3`	Add after reports, issues table, reflection and gitignore update